



RAPPORT D'AUDIT DE SÉCURITÉ D'UNE APPLICATION WEB

APPLICATION AUDITÉE : OWASP Juice Shop

URL : <http://127.0.0.1:42000>

TYPE DE TEST : Test de sécurité applicative (Black Box)

MÉTHODOLOGIE : OWASP Top 10

OUTILS UTILISÉS : OWASP ZAP, Burp Suite

SYSTÈME : Kali Linux

AUTEUR : DAOU R.Kris

Sommaire

Introduction -----

I- Portée de l’audit -----

II- Méthodologie -----

III- Synthèse des vulnérabilités identifiées -----

IV- Détails des vulnérabilités -----

Conclusion -----

Introduction

Dans un contexte numérique en constante évolution, les applications web constituent désormais l'épine dorsale de nombreuses organisations, des startups innovantes aux plateformes de commerce électronique établies. Cependant, cette dépendance croissante s'accompagne d'une augmentation exponentielle des cybermenaces. Selon l'OWASP (Open Web Application Security Project), plus de 70% des applications web présentent au moins une vulnérabilité critique exploitable.

La sécurité des applications web n'est plus une option, mais une nécessité stratégique. Les violations de données peuvent entraîner des pertes financières considérables, une atteinte à la réputation et des conséquences juridiques graves, notamment avec l'application de réglementations comme le RGPD.

Objectifs de l'évaluation

Ce rapport présente les résultats d'une évaluation approfondie des vulnérabilités réalisée sur l'OWASP Juice Shop . Les objectifs principaux de cette analyse sont :

- _ Identifier les failles de sécurité présentes dans l'application en utilisant des méthodologies de piratage éthique
- _ Cartographier les vulnérabilités selon le référentiel OWASP Top 10
- _ Évaluer le niveau de risque associé à chaque vulnérabilité découverte
- _ Proposer des recommandations concrètes et actionnables pour la remédiation
- _ Fournir une documentation complète permettant aux équipes de développement de renforcer la posture de sécurité de l'application

I. PORTÉE DE L'AUDIT

1.1 Périmètre d'intervention

L'audit de sécurité a été conduit selon les paramètres techniques et méthodologiques suivants :

Application cible

- _ Nom : OWASP Juice Shop
- _ URL d'accès : <http://127.0.0.1:42000>
- _ Environnement : Local isolé

Méthodologie appliquée

Type d'audit : Black Box Testing (test en boîte noire)

Approche : Simulation d'un attaquant externe sans connaissance préalable de l'architecture interne

Niveau d'accès : Aucun accès au code source, à la documentation technique ou aux configurations serveur

II- Méthodologie

L'évaluation a été menée en suivant une approche structurée de tests d'intrusion (penetration testing), combinant :

- Référentiel **OWASP Top 10 (2021)**

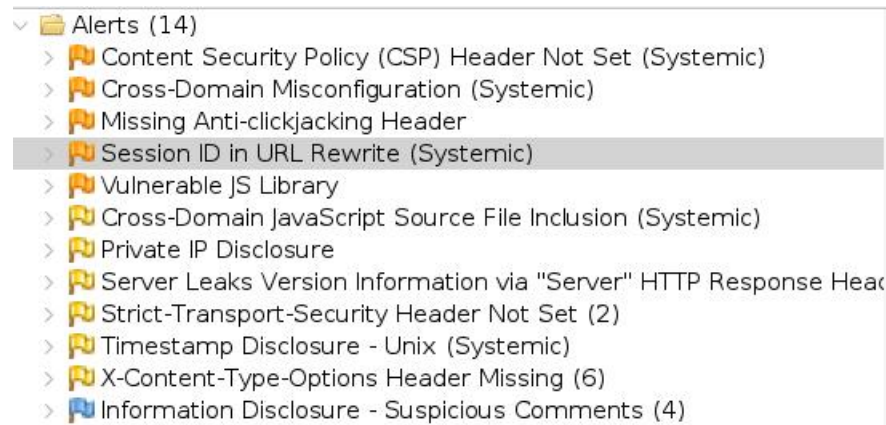
- Exploration manuelle de l'application
- Interception et analyse des requêtes HTTP
- Analyse automatique via scanner de vulnérabilités

Outils utilisés

- **OWASP ZAP** : Scan automatisé et détection de mauvaises configurations
- **Burp Suite Community** : Interception et modification des requêtes HTTP
- **Navigateur web** (proxy configuré)

III- Synthèse des vulnérabilités identifiées

Vulnérabilité	Méthode	Catégorie - OWASP	Niveau de gravité
Broken Access Control (IDOR)	Manuel (Burp)	A01	Critique
SQL Injection (Auth Bypass)	Manuel (Burp)	A03	Critique
Content Security Policy (CSP)	Manuel / ZAP	A05	Moyenne
Mauvaise configuration inter-domaines (CORS)	Automatique (ZAP)	A05	Moyenne
Inclusion de fichiers JavaScript cross domain	Automatique (ZAP)	A06	Faible



IV- Détails des vulnérabilités

*** Vulnérabilité 1 : Broken Access Control (IDOR)**

Catégorie OWASP : A01 – Broken Access Control

Gravité : Critique

Méthode de détection : Manuelle (Burp Suite)

CVSS Score : 9.1 (Critique)

Description

Une vulnérabilité de type IDOR (Insecure Direct Object Reference) a été identifiée dans l'application OWASP Juice Shop. Cette faille permet à un utilisateur authentifié d'accéder ou de modifier des ressources appartenant à d'autres utilisateurs en manipulant simplement les identifiants d'objets (ID) dans les requêtes HTTP.

L'application ne vérifie pas si l'utilisateur connecté possède les droits nécessaires pour accéder aux ressources demandées. Elle se contente de valider l'authentification, mais néglige totalement l'autorisation (vérification des permissions).

Cette vulnérabilité affecte les principes fondamentaux de sécurité :

_ Confidentialité : Accès non autorisé aux données sensibles d'autres utilisateurs

_ Intégrité : Modification possible des données d'autrui

_ Contrôle d'accès : Absence de vérification des permissions au niveau objet

Localisation de la vulnérabilité

Endpoint vulnérable : /rest/basket/[basket]/5

Méthode HTTP : GET / PUT / DELETE

Paramètre exploitable : basketId ou userId dans l'URL

*** Vulnérabilité 02 : Injection SQL (Auth Bypass)**

Catégorie OWASP : A03 – Injection

Gravité : Critique

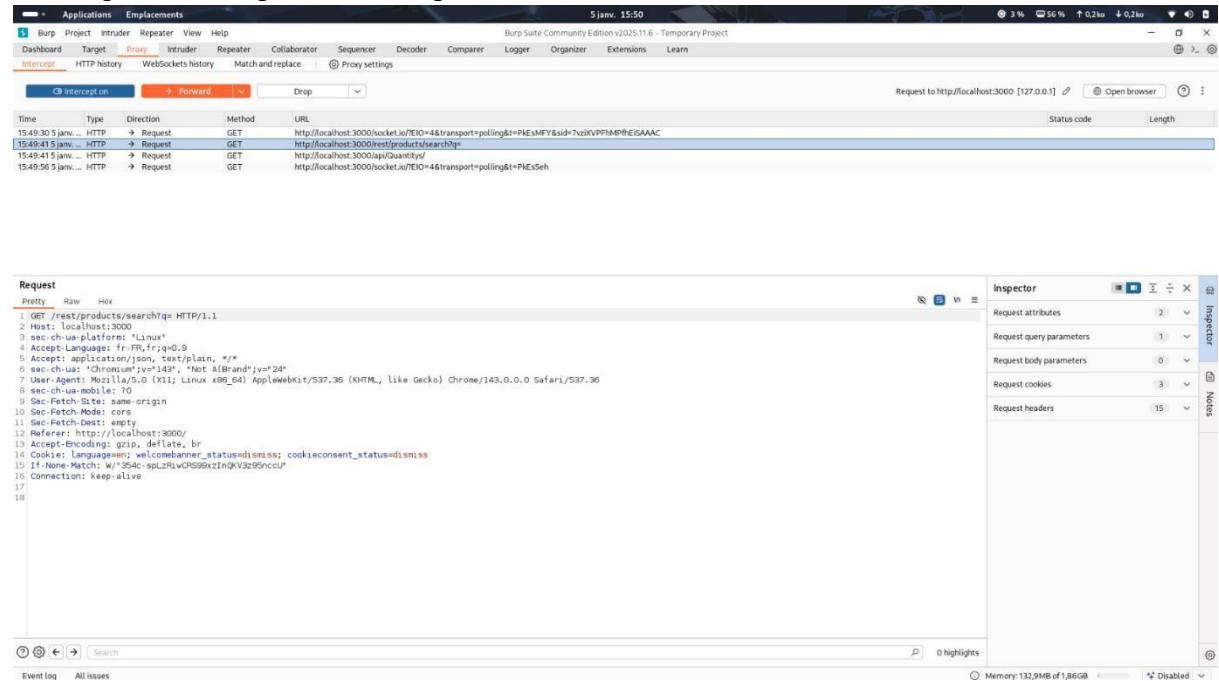
Description

Une vulnérabilité de type **Injection SQL** a été identifiée lors de la manipulation de paramètres transmis à l'API de recherche de produits. L'application ne filtre pas correctement les entrées utilisateur, ce qui permet l'injection de requêtes SQL malformées.

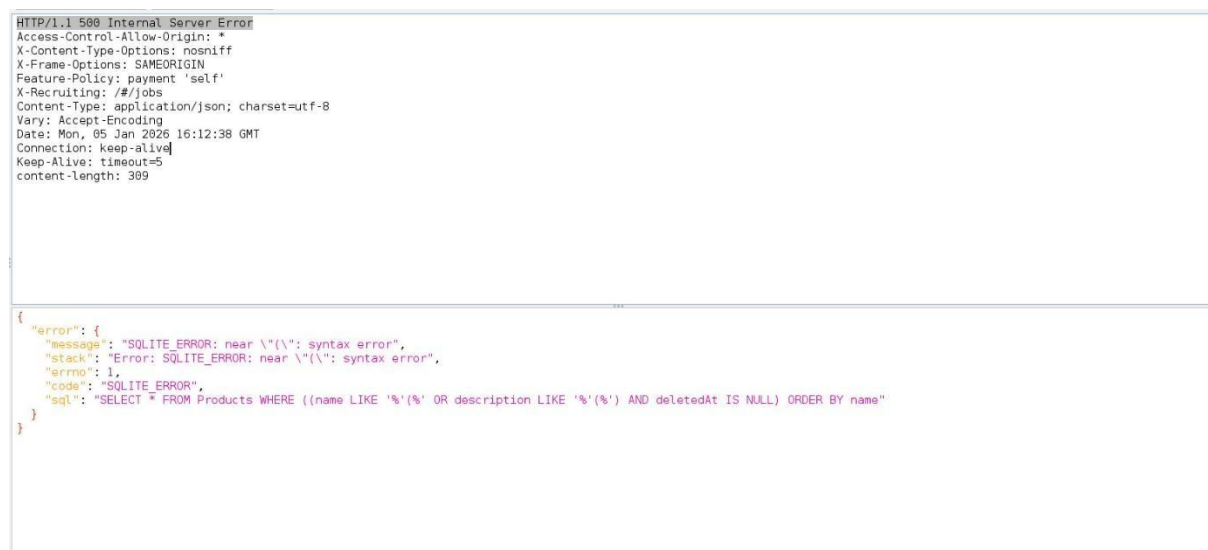
Lors de l'envoi d'une requête modifiée, l'application retourne une erreur SQL révélant la structure interne de la requête : `SQLITE_ERROR: near "(" syntax error`

Captures d'écran

- Requête interceptée dans Burp Suite



- Message d'erreur SQL retourné



Impact

- Divulgarion d'informations internes sur la base de données
- Risque d'accès ou de modification non autorisée des données

- Compromission potentielle de l'application

Recommandations

- Utiliser des **requêtes préparées (prepared statements)**
- Mettre en place une **validation stricte des entrées utilisateur**
- Désactiver l'affichage des erreurs SQL en production

*** Vulnérabilité 03 : Content Security Policy (CSP) Header non défini**

Catégorie OWASP : A05 – Mauvaise configuration

Gravité : Moyenne

Description

L'en-tête HTTP **Content-Security-Policy** est absent des réponses serveur.

Capture d'écran



Impact

- Augmentation du risque d'attaques XSS
- Chargement de ressources externes non contrôlées

Recommandations

- Définir une politique CSP restrictive
- Limiter les sources autorisées (script-src, style-src)

*** Vulnérabilité 04 : Mauvaise configuration inter-domaines (CORS)**

Catégorie OWASP : A05 – Mauvaise configuration

Gravité : Moyenne

Description

Des règles **CORS trop permissives** ont été identifiées. Cette configuration permet à des domaines externes non autorisés d'accéder aux ressources de l'application, exposant potentiellement des données sensibles. Une telle ouverture accroît le risque d'exploitation par des attaquants capables d'effectuer des requêtes inter sites malveillantes.

Capture d'écran

Mauvaise configuration inter-domaines	
URL :	http://127.0.0.1:42000/
Risque :	🟡 Medium
Confiance:	Medium
Paramètre :	
Attaque :	
Preuve :	Access-Control-Allow-Origin: *
Id CWE :	264
Id WASC :	14
Source :	Scan passif (10098 - Mauvaise configuration inter-domaines)
Input Vector:	
Déscription:	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
Autres informations :	

Impact

- exfiltration d'informations privées
- Exécution d'actions non autorisées au nom de la victime (CSRF amplifié)

Recommandations

- Implémenter une liste blanche stricte des origines autorisées
- Ajouter des mécanismes de défense en profondeur

* Vulnérabilité 05 : Inclusion de fichiers JavaScript cross-domain

Catégorie OWASP : A06 – Software and Data Integrity Failures

Gravité : Faible

Description

L'application charge des fichiers JavaScript externes , exposant les utilisateurs à un risque d'injection de codes malveillants.

Capture d'écran

Cross-Domain JavaScript Source File Inclusion	
URL :	http://127.0.0.1:42000/
Risque :	🟡 Low
Confiance:	Medium
Paramètre :	//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js
Attaque :	
Preuve :	<script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
Id CWE :	829
Id WASC :	15
Source :	Scan passif (10017 - Cross-Domain JavaScript Source File Inclusion)
Input Vector:	
Déscription:	The page includes one or more script files from a third-party domain.
Autres informations :	

L'application charge des fichiers JavaScript depuis des sources externes sans mécanisme d'intégrité.

Impact

- Compromission totale de l'application côté client

- Vol de données sensibles et d'informations d'authentification

Recommandations

- Utiliser l'attribut **Subresource Integrity (SRI)**
- **Content Security Policy (CSP)**

V- Conclusion

L'audit de sécurité réalisé sur l'application OWASP Juice Shop a révélé plusieurs vulnérabilités critiques nécessitant une intervention immédiate. L'identification de failles telles que le Broken Access Control (IDOR) et l'injection SQL démontre que des lacunes importantes subsistent dans les mécanismes de validation des entrées et de contrôle d'accès. Ces vulnérabilités, classées parmi les menaces OWASP Top 10, exposent l'application à des risques majeurs : exfiltration de données sensibles, manipulation non autorisée de ressources utilisateur, et compromission potentielle de l'intégrité de la base de données. Dans un contexte de production, de telles failles auraient des conséquences désastreuses tant sur le plan financier que réputationnel. Ce projet souligne une réalité fondamentale : la sécurité ne peut être un ajout a posteriori. Elle doit être intégrée dès la phase de conception à travers l'adoption d'un modèle de développement sécurisé (Security by Design) et l'application systématique de principes tels que la validation stricte des entrées, la défense en profondeur et le principe du moindre privilège.